Laboratorio de gestión de riesgos

Academia Horizonte · Informe de trabajo académico · Datos ficticios

Objetivo y alcance

Una campaña de matrícula de siete días necesita completar las solicitudes dentro del plazo y conservar los registros confirmados para poder recuperarlos. Se analizan la plataforma web, la base de datos y las copias de seguridad.

Condiciones conocidas del caso: una única instancia de base de datos, restauración de copias sin probar y cuenta de aplicación con permisos administrativos. Son condiciones ficticias y no describen la configuración real del proyecto entregado.

Decisión para dirección

Priorizar las copias separadas y una restauración completa probada antes de la campaña. Esta medida permite demostrar que se conservan las matrículas y medir cuándo podría volver el servicio. Los criterios propuestos son RPO de 1 hora y RTO de 4 horas; dirección debe aprobarlos. La reducción de privilegios sigue siendo necesaria y se propone en segundo lugar.

Evaluación común

Puntuación = probabilidad × impacto, en escalas de 1 a 3. Bajo: 1-2; medio: 3-4; alto: 6-9. Estas reglas pertenecen al laboratorio, no al ENS ni a NIST. La incertidumbre se declara como supuesto y no implica probabilidad alta.

Riesgo	P	I	Resultado	Prioridad
Recuperación no probada	2	3	6 / Alto	1
Privilegios excesivos	2	3	6 / Alto	2

Estado de la entrega

Proyecto Next.js y TypeScript preparado con formulario guiado, evaluación, medidas, acceso protegido y persistencia. La documentación distingue las pruebas locales de las evidencias externas pendientes. **Preview publicada; registro remoto pendiente:** falta configurar Supabase y las variables de acceso. El repositorio remoto y el acceso del profesor siguen pendientes.

Dos riesgos completos

01 / Pérdida de registros confirmados

Debido a que no se ha probado la restauración de las copias, un fallo del almacenamiento podría provocar pérdida de acceso a los registros confirmados de la base de datos, causando imposibilidad de reconstruir matrículas y afectando al objetivo de conservar y recuperar registros.

Probabilidad 2: fallo plausible, sin indicios concretos de que ocurrirá durante la campaña. La ausencia de pruebas no demuestra alta frecuencia. **Impacto 3:** si las copias no permiten recuperar los registros, la pérdida sería definitiva. **Nivel: 6, alto.**

Supuesto: se desconoce si las copias disponibles recuperan todos los registros. **Medida:** copias horarias cifradas en almacenamiento separado y restauración completa aislada antes de la campaña. **Responsable:** sistemas. **Prioridad:** 1, inmediata.

Verificación: simular pérdida de instancia, restaurar, comparar recuentos e integridad y comprobar matrículas completas. Medir RPO y RTO contra los criterios aprobados. **Estado:** propuesta; no existe evidencia de implantación. No se reduce la valoración automáticamente.

02 / Alteración por privilegios excesivos

Debido a los permisos administrativos de la cuenta de aplicación, su uso indebido tras un posible compromiso podría provocar borrado o alteración de tablas de la base de datos, causando interrupción y reconstrucción de matrículas, y dificultando completar solicitudes dentro del plazo.

Probabilidad 2: escenario plausible por los permisos, sin indicios de intrusión. **Impacto 3:** la reconstrucción podría superar los siete días y comprometer el plazo. **Nivel: 6, alto.**

Supuestos: posible compromiso de la cuenta y tiempo de recuperación no medido. **Medida:** rol exclusivo con CRUD solo en tablas autorizadas, separar migraciones, revocar privilegios de esquema y rotar la credencial anterior. **Responsable:** administración de BD. **Prioridad:** 2, antes de campaña.

Verificación: probar CRUD autorizado y confirmar denegación de CREATE, DROP y acceso a otras tablas con el rol real de ejecución. Repetir la prueba funcional tras rotar. **Estado:** propuesta; pendiente de prueba en PostgreSQL.

Implementación y evidencias

Cómo comprobar el trabajo

Consultar README.md. En Windows: npm.cmd ci; npm.cmd run setup:local; npm.cmd run dev. El comando inicial genera secretos en .env.development.local, muestra la contraseña solo en la terminal e incorpora los dos riesgos si la base está vacía. Guardar la credencial en Bitwarden. Abrir http://127.0.0.1:3000.

SQLite se usa únicamente en desarrollo. En Vercel se exige PostgreSQL: no se escriben registros en un sistema de archivos efímero. Las consultas están parametrizadas y las entradas se validan en el servidor con Zod. Los registros requieren sesión; las escrituras requieren además un origen autorizado.

Validación y trazabilidad

El resultado actualizado de las pruebas y sus límites se registra en docs/pruebas.md. El identificador del commit se obtiene con git rev-parse HEAD. La URL y el SHA efectivamente desplegados deben registrarse en docs/despliegue.md después de publicar. No se inventan evidencias remotas.

Seguridad y fuentes

La matriz SEG-01 a SEG-08 relaciona finalidad, referencia, implementación, prueba y evidencia en docs/requisitos-seguridad.md. Se consultaron el ENS, RD 311/2022, anexo II (op.acc.4, op.exp.2 y mp.sw.1), y NIST SP 800-53 Rev. 5, edición 2020 actualizada el 10/12/2020 (IA-5, AC-6 y SI-10). La ficha NIST advierte de Release 5.2.0; el trabajo conserva la edición solicitada.

Fuentes: boe.es/buscar/act.php?id=BOE-A-2022-7191; csrc.nist.gov/pubs/sp/800/53/r5/upd1/final. Enlaces completos y condiciones de reutilización en docs/fuentes.md, consultados el 22/10/2026. Se redactan resúmenes propios, sin redistribuir las normas. Esta adaptación didáctica no acredita conformidad completa.

Decisión de IA revisada

Se descartó asignar probabilidad alta por el mero hecho de que las copias no estuvieran probadas. Se fijó P=2 y se declaró la incertidumbre. Es una revisión del propio asistente, documentada en docs/decision-ia.md; queda pendiente la revisión personal del alumno.

Para completar la entrega externa

La Preview está en laboratorio2-riesgos-preview-spamtom4444.vercel.app, protegida por Vercel. Configurar Supabase y variables separadas por entorno y redesplegar con --environment preview. Crear repositorio privado GitHub, subir el commit y conceder acceso al profesor. Registrar URL Preview, SHA, fecha, pruebas remotas y capturas de configuración sin valores sensibles.